

Chapter 4

Software Security Analysis Phase



Table of contents

1. Purpose of the Analysis Phase.....	4
2. Inputs to the Analysis Phase.....	5
3. Main Activities and Steps.....	6
• A. Transform your DFD-0 into DFD-1 and define the Data Entities.....	7
• B. Identify Internal Data Entities (Inside the System Boundary).....	10
• C. Build the Actor–Entity Matrix.....	11
• D. Classify Data by Sensitivity (Level Tags).....	12
• E. Data Entities with Sensitivity Tags.....	13
4. Model Data Flows and Trust Boundaries (Trust Zones).....	16
• The Public Internet Zone.....	18
• The PCI External Zone.....	20
• The PCI Internal Zone.....	22
• Internal Network Zone.....	24
• The Admin Network Zone.....	26
• The Third-Party Zone.....	28
4. Identify Preliminary Threats (Boundary-Level STRIDE).....	30

Table of contents



5. Map Threats to Security Requirements.....	38
6. Create Requirement Traceability Matrix (RTM).....	40
7. Chapter Project – Analysis Phase.....	44

1. Purpose of the Analysis Phase

The **Analysis Phase** transforms the approved requirements into a **structured understanding** of the system's behavior, data, interactions, and risks.

In security-focused SSDLC, the goal is to:

- Validate that all requirements (functional + non-functional + security) are consistent and complete.
- Identify **data flows, assets, threats, and trust boundaries** before design begins.
- Prepare models (DFDs, use-case diagrams, threat models, requirement matrices) that support **secure architecture decisions**.

2. Inputs to the Analysis Phase

From the Requirements Phase you already have:

1. Approved System Scenario (ShopEase).
2. Functional Requirements list.
3. Non-Functional Requirements list.
4. Security Requirements list.
5. Requirement Classification Matrix (RCM).
6. Compliance Traceability Matrix (CTM).

3. Main Activities and Steps

Step 1 – Requirement Verification and Refinement

Objective: Ensure requirements are consistent, feasible, testable, and security-aware.

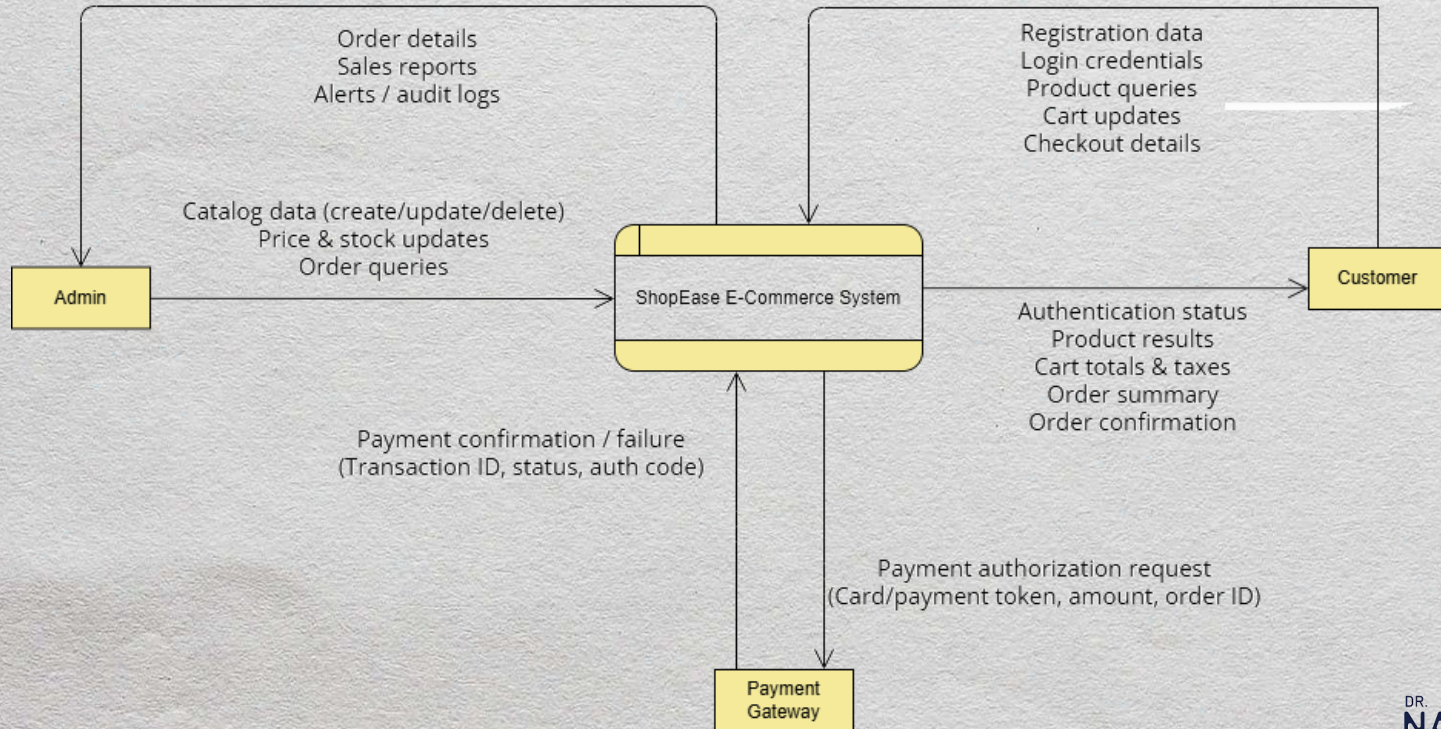
Actions:

- Remove duplication or conflicts (e.g., two password policies).
- Cross-check requirements against laws and standards (use CTM).
- Re-confirm priorities (High / Medium / Low).
- Validate inputs/outputs for completeness.

Deliverables: Updated and verified requirement specification.

3. Main Activities and Steps

Step 2 – A. Transform your DFD-0 into DFD-1 and define the Data Entities



3. Main Activities and Steps

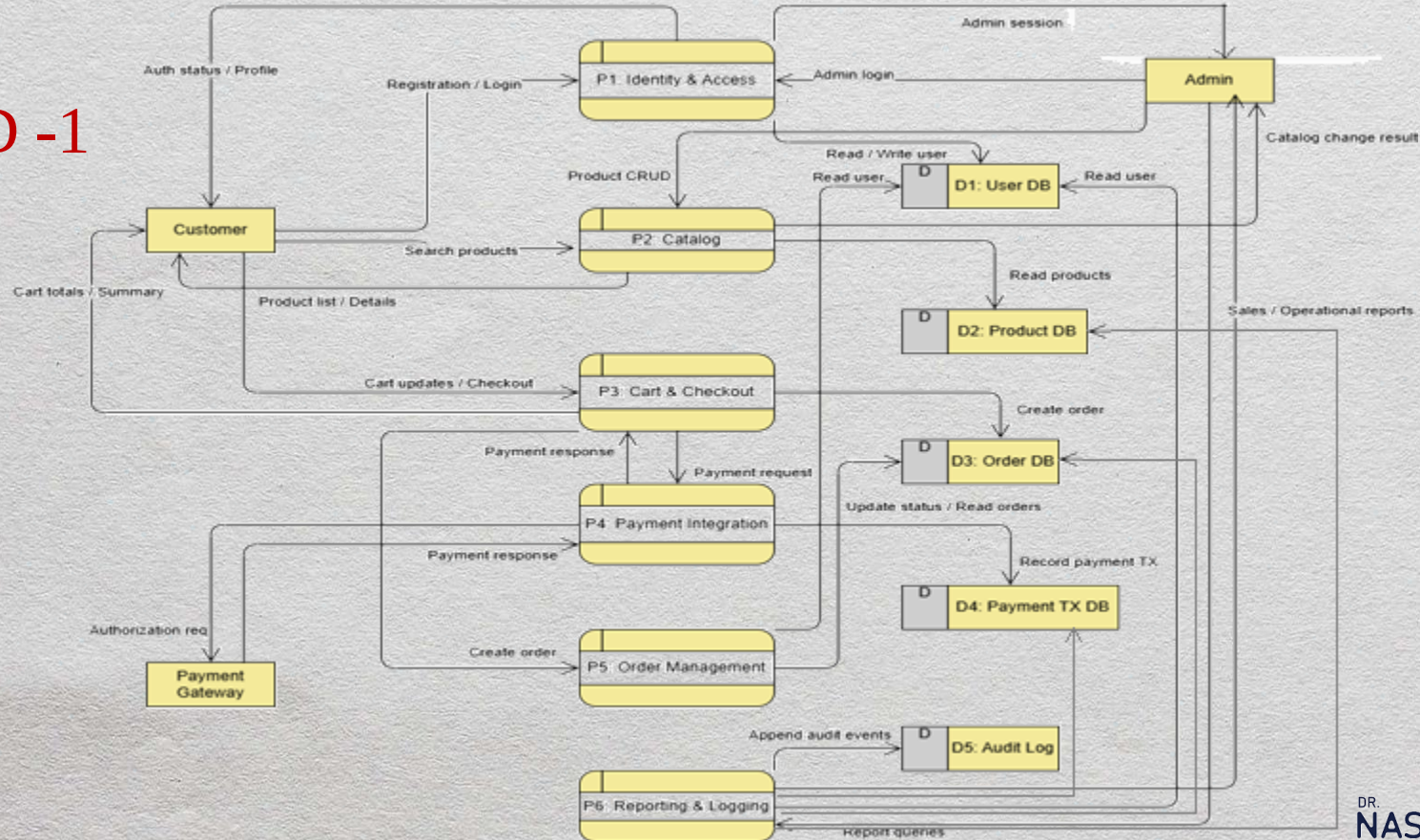
What are the Steps involved in changing level 0 to level 1???

Read the case study found in your chapter
Chapter4/Case Study/ What is DFD.pdf



3. Main Activities and Steps

DFD -1



3. Main Activities and Steps

B. Identify Internal Data Entities (Inside the System Boundary)

These are the logical data stores or core structures within the e-commerce system.

Entity Name	Description / Examples	Main Operations	Storage Type
User Table	Customer + Admin profiles (name, email, password hash, role).	Create / Update / Delete / Authenticate.	Relational DB table.
Product Catalog	Product ID, name, description, price, stock.	Read by Customer; managed by Admin.	Database or CMS.
<u>Shopping Cart</u>	Temporary list of product IDs + quantity.	Add, Update, Remove items.	Session store / DB.
Order Record	Customer ID, cart details, total, date, status.	Insert on checkout; read for history.	Database table.
Payment Transaction	Payment token, order ID, amount, status.	Create on gateway response.	Database table.
Audit Log	Login attempts, admin actions, errors.	Append records on each critical event.	Log file / SIEM system.

3. Main Activities and Steps

C. Build the Actor–Entity Matrix

After building your Data Entity, you have to create this matrix as it links each actor to the internal entities they can access or modify. We need this matrix as it supports **authorization** and **DFD flow validation**.

Actor / Entity	User Table	Product Catalog	Shopping Cart	Order Record	Payment Transaction	Audit Log
Customer	Create (Registration) / Read (Update Profile)	Read	Create / Update / Delete	Create (Checkout) / Read (Order History)	Create (via Gateway)	—
Admin	Read / Update (Manage Users)	Create / Update / Delete	—	Read / Update (Modify Status)	Read (for reporting)	Create / Read
Payment Gateway	—	—	—	Read (Order Amount & ID)	Create (Confirm Payment)	—

3. Main Activities and Steps

D. Classify Data by Sensitivity (Level Tags)

Every entity and data attribute must be classified so you know how to protect it.

Classification	Meaning	Examples in ShopEase	Protection Needed
Public	Information safe to disclose publicly.	Product names, prices, general descriptions.	No encryption; integrity checks only.
Confidential	Internal business or non-public data.	Admin reports, inventory levels, sales totals.	Access control, auth logging.
Sensitive (PII)	Personally Identifiable Information (PII).	Name, email, phone, shipping address.	Encryption at rest + in transit; GDPR controls.
Highly Sensitive (Payment)	Financial or credential data.	Card number token, CVV (encrypted), login password hash.	PCI-DSS encryption, hashing, vault storage, least privilege.

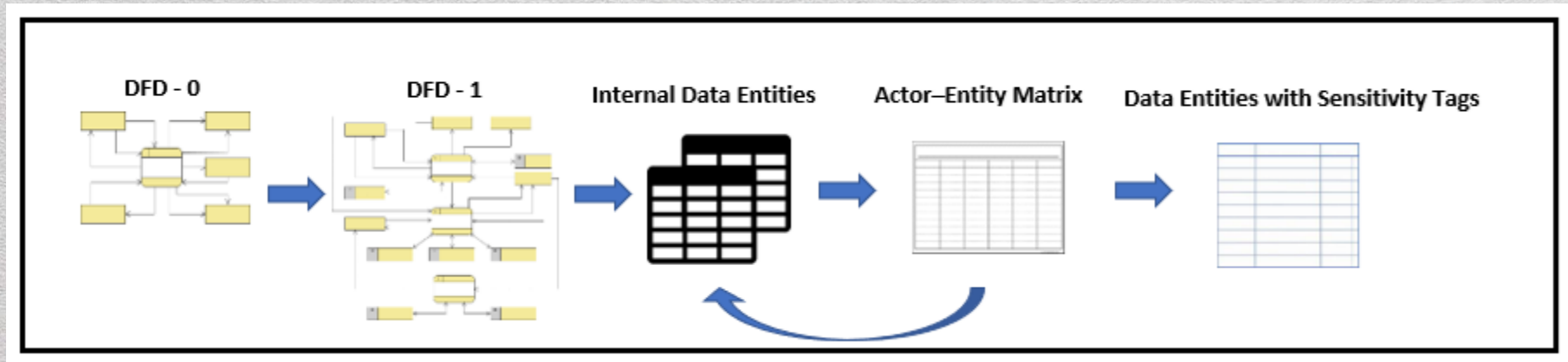
3. Main Activities and Steps

E. Data Entities with Sensitivity Tags

A concise list of key assets for security prioritization.

Asset Name	Type	Sensitivity Level	Owner / Actor	Primary Threats (Expected)
User Table	Database Record	Sensitive (PII)	Customer	Spoofing, Disclosure
Product Catalog	Database Hash	Highly Sensitive	Customer	Spoofing, EoP
<u>Shopping Cart</u>	Session store / DB	Public	Customer	Tampering
Order Record	Database	Confidential	Customer / Admin	Disclosure, Repudiation
Payment Transaction	API / DB Token	Highly Sensitive	Payment Gateway	Disclosure, Tampering
Audit Log	File / SIEM	Confidential	Admin	Repudiation, Integrity Loss

3. Main Activities and Steps



3. Main Activities and Steps

Step 3 – Model Data Flows and Trust Boundaries (Trust Zones)

- A. Identify **trust boundaries (Trust Zones)** (e.g., between system and Payment Gateway).
- B. Highlight where sensitive data crosses boundaries.
- C. Output: **DFD diagrams + Boundary Map.**

3. Main Activities and Steps

Step 3 – Model Data Flows and Trust Boundaries (Trust Zones)

A. What are Trust boundaries (Trust Zones)???

Trust Zone	Definition	Trust Level
Public Internet	The untrusted external network; includes any unknown or anonymous user or system.	✗ Untrusted
PCI External	Systems outside the Cardholder Data Environment (CDE) but that interface with it.	⚠ Conditionally trusted
PCI Internal (CDE)	The Cardholder Data Environment (CDE): systems that store, process, or transmit cardholder data (e.g., PAN).	🔒 Highly trusted (but high-risk)

3. Main Activities and Steps

Step 3 – Model Data Flows and Trust Boundaries (Trust Zones)

A. What are Trust boundaries (Trust Zones)???

Trust Zone	Definition	Trust Level
Corporate / Internal Network	The organization's internal trusted network for employees and business systems.	☒ Trusted
Admin Network	A restricted, high-privilege network segment used only for system administration.	☒ Critical trust
Third-Party / Partner Network	External but authenticated business partners or SaaS providers.	Conditional trust

3. Main Activities and Steps

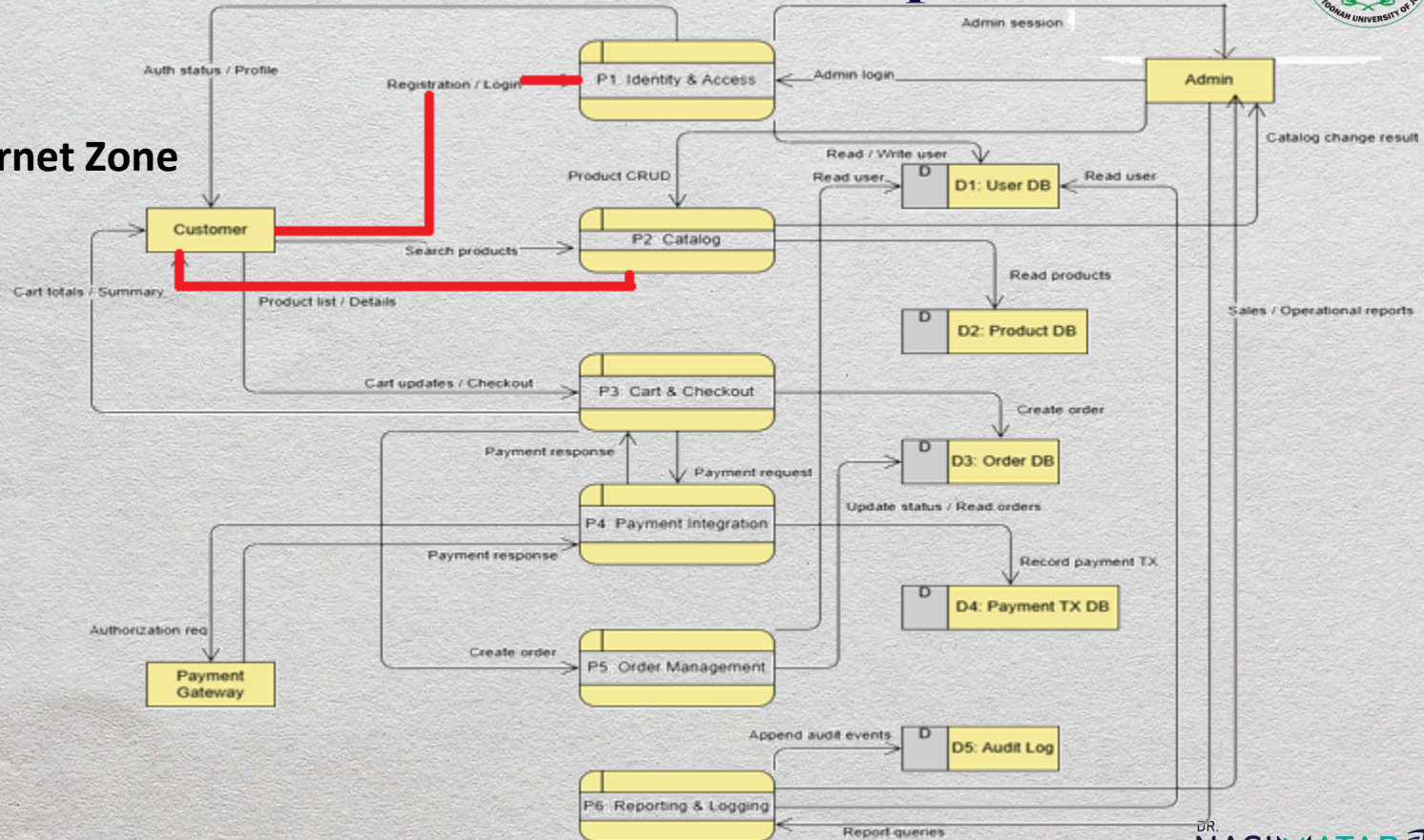
Step 3 – The Public Internet Zone

Trust Zone	From → To	Data Flows (Example)	Sensitivity	Primary Protection Domain (CIA)
Public Internet	Customer → P1 (Identity Service)	Login credentials, registration data	Medium	Confidentiality, Integrity
	P2 (Catalog) → Customer	Product listings, images, prices	Low	Integrity, Availability

3. Main Activities and Steps

Step 3 –

The Public Internet Zone



3. Main Activities and Steps

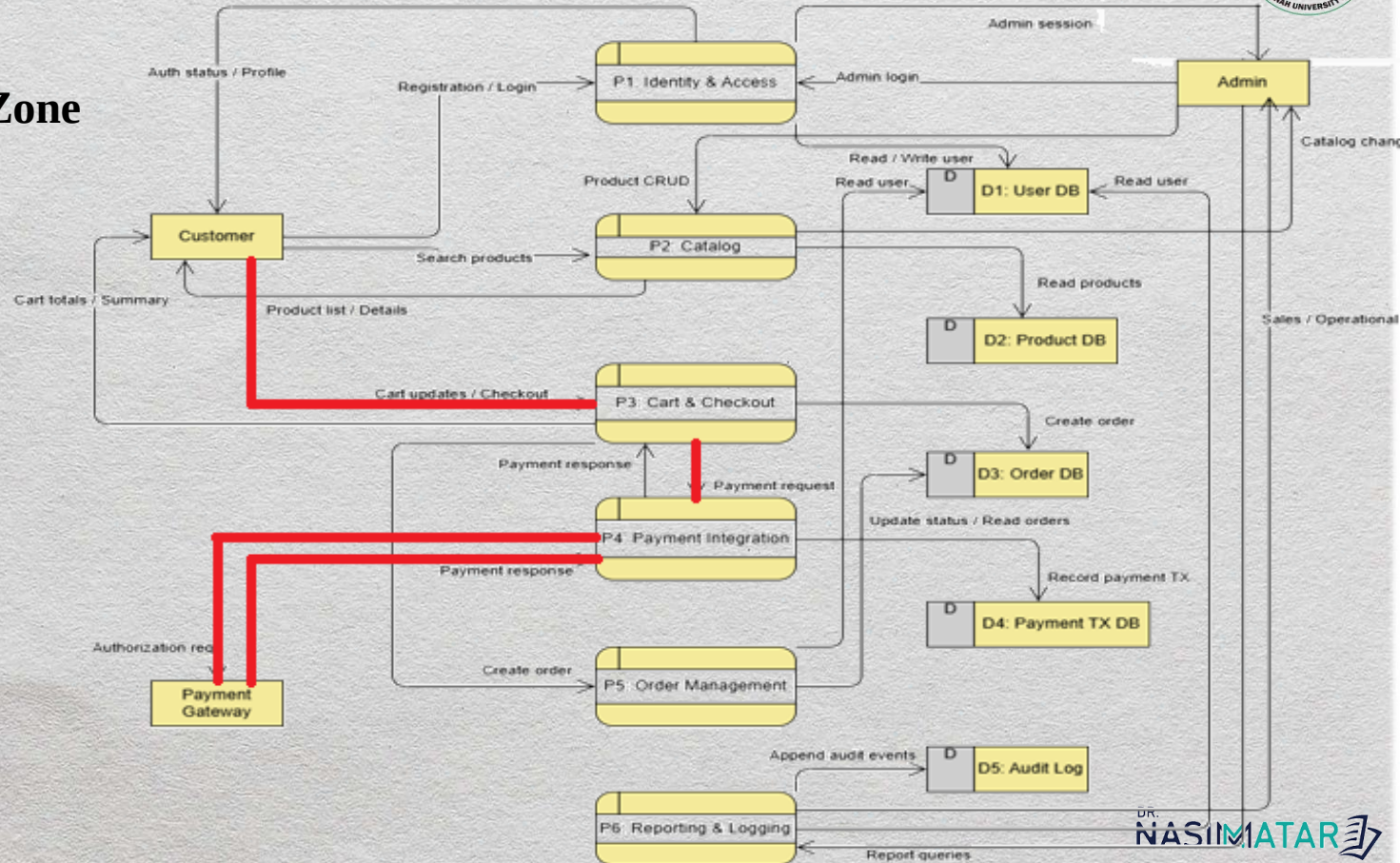
Step 3 – The PCI External Zone

Trust Zone	From → To	Data Flows (Example)	Sensitivity	Primary Protection Domain (CIA)
PCI External	Customer → P3 (Cart & Checkout)	Cart items, shipping address, payment initiation request	Medium	Integrity
	P3 → P4 (Payment Integration)	Tokenized checkout payload, order metadata	Medium	Integrity
	P4 → Payment Gateway	Redirect URL, payment session ID, tokenized data	Medium–High	Confidentiality, Integrity
	Payment Gateway → P4	Payment confirmation, transaction ID	Medium	Integrity (signature validation)

3. Main Activities and Steps

Step 3 –

The PCI External Zone



3. Main Activities and Steps

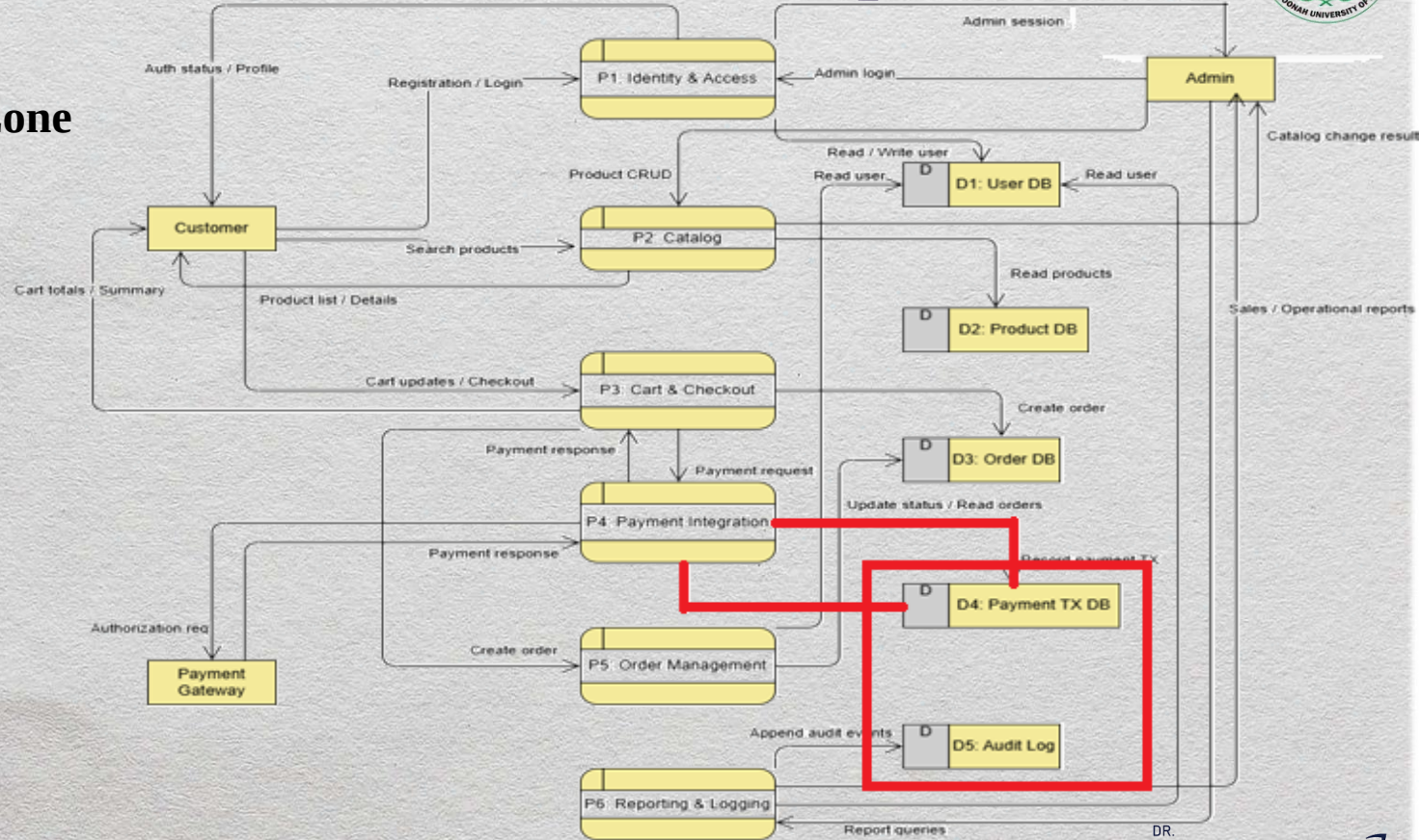
Step 3 – The PCI Internal Zone

Trust Zone	From → To	Data Flows (Example)	Sensitivity	Primary Protection Domain (CIA)
PCI Internal	P4 → D4 (Payment TX DB)	Encrypted/tokenized transaction record	Critical	Confidentiality, Integrity
	D4 → P4	Masked PAN, transaction status for receipt	High	Confidentiality
	D4 → D5 (Audit Log)	PCI-relevant audit event (e.g., “payment processed”)	High	Integrity, Confidentiality

3. Main Activities and Steps

Step 3 –

The PCI Internal Zone



3. Main Activities and Steps

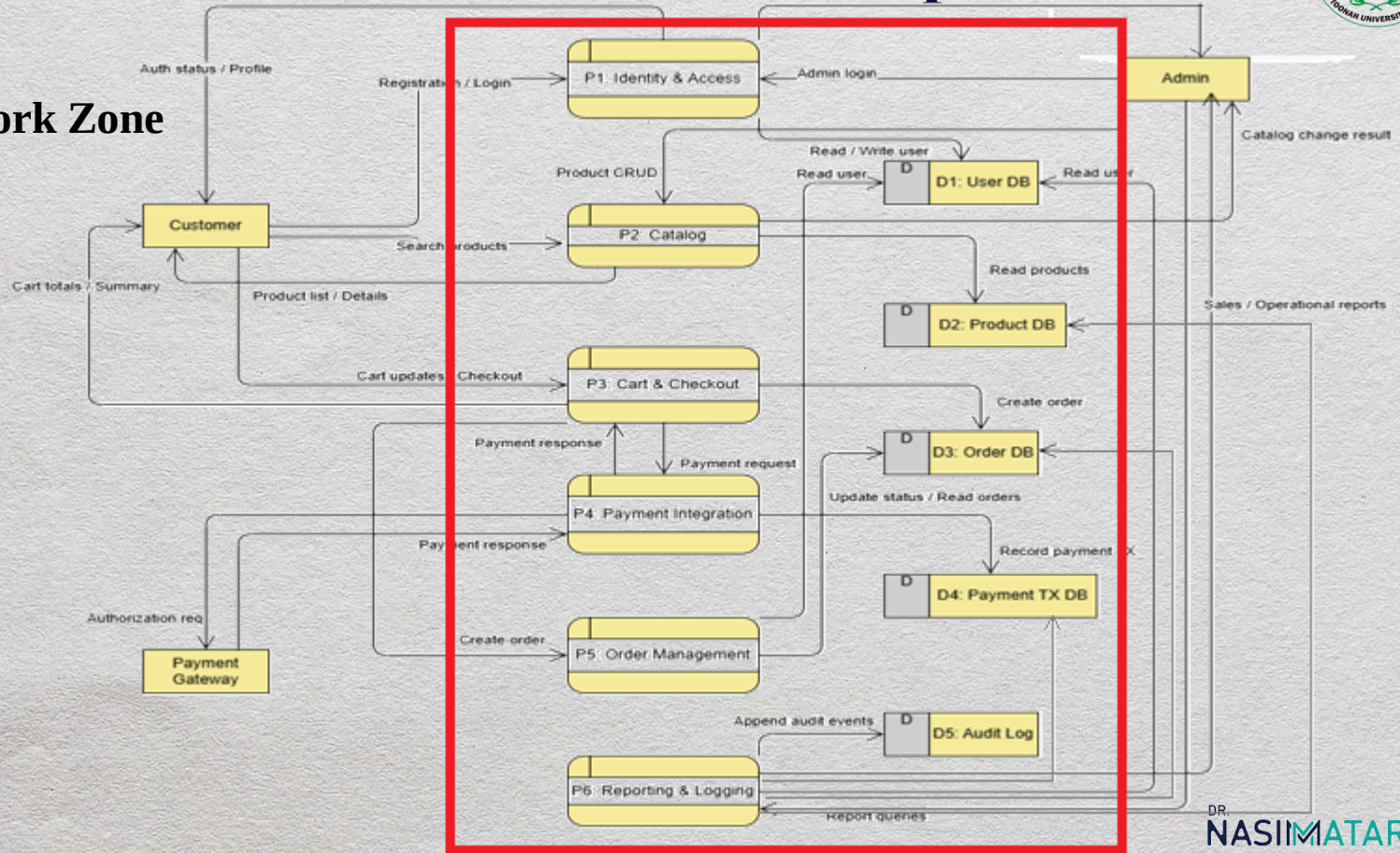
Step 3 – Internal Network Zone

Trust Zone	From → To	Data Flows (Example)	Sensitivity	Primary Protection Domain (CIA)
Internal Network	P3 → P5 (Order Management)	New order details (excluding raw card data)	Medium	Integrity
	P5 → D3 (Order DB)	Order status updates, fulfillment info	Medium	Integrity
	P6 (Reporting) → D3 / D5	Analytics queries, compliance report generation	Medium	Confidentiality
	P5 → External Fulfillment API	Shipment request (address, items)	Medium	Integrity, Availability

3. Main Activities and Steps

Step 3 –

Internal Network Zone



3. Main Activities and Steps

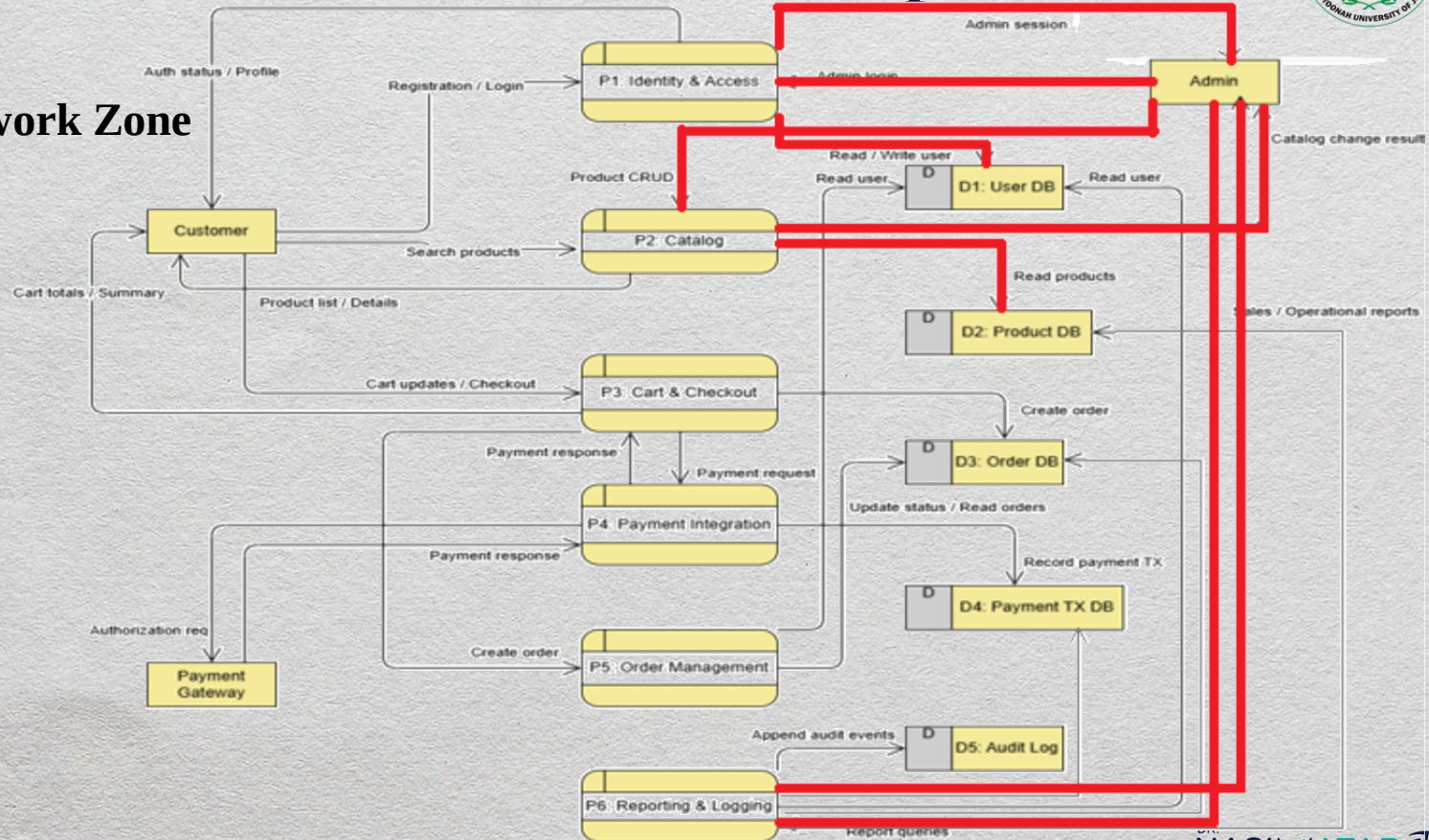
Step 3 – The Admin Network Zone

Trust Zone	From → To	Data Flows (Example)	Sensitivity	Primary Protection Domain (CIA)
Admin Network	Admin → P1	Admin login with MFA, session cookie	High	Confidentiality, Integrity
	Admin → D1 (User DB)	User role modification, password reset	High	Integrity, Confidentiality
	Admin → D2 (Product DB)	Catalog updates (“Catalog change result”)	Medium–High	Integrity
	P6 → Admin	Audit log export, system health dashboard	High	Confidentiality
All Connections related to Admin Entity				

3. Main Activities and Steps

Step 3 –

The Admin Network Zone



3. Main Activities and Steps

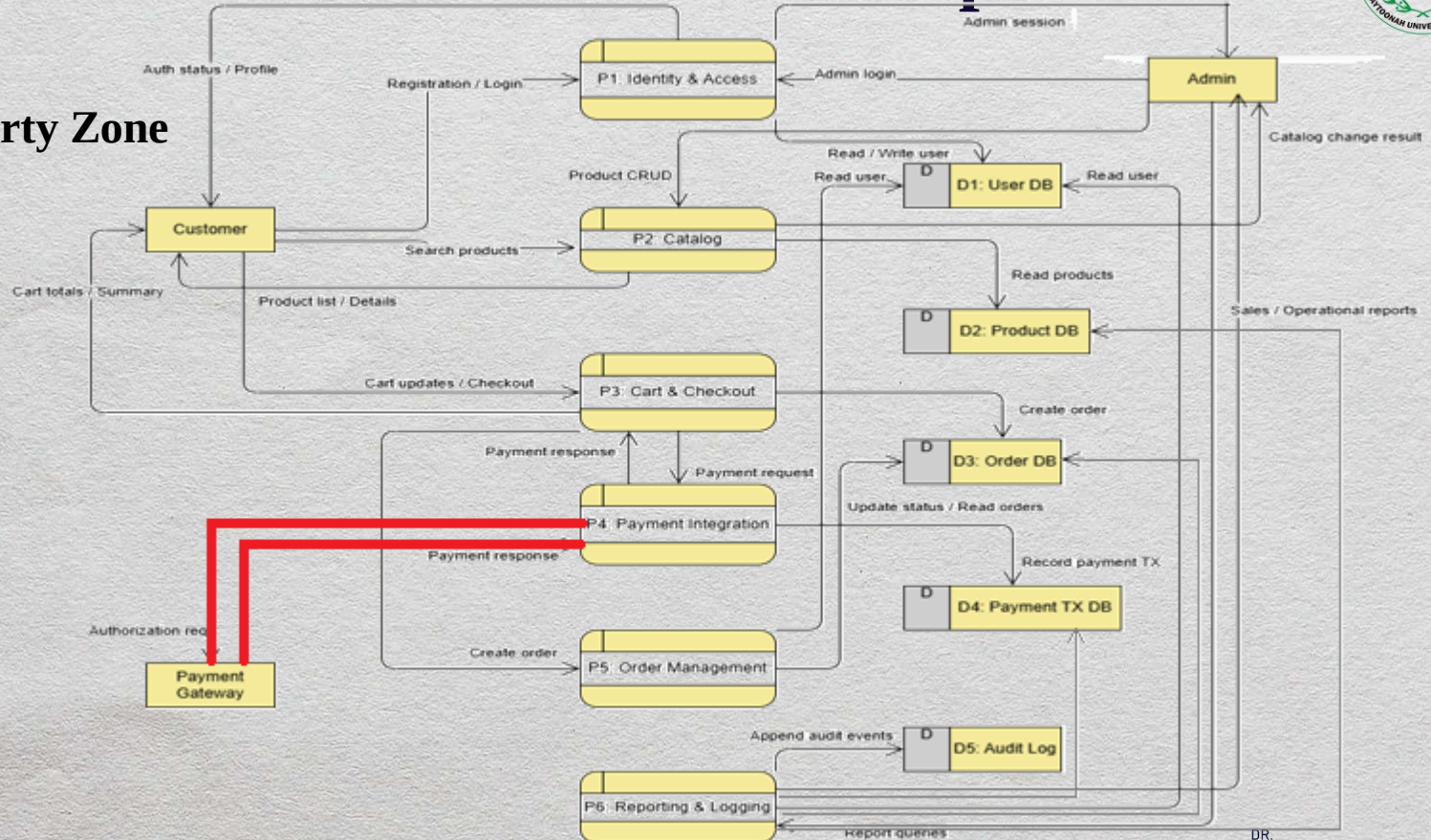
Step 3 – The Third-Party Zone

Trust Zone	From → To	Data Flows (Example)	Sensitivity	Primary Protection Domain (CIA)
Third-Party Network	Payment Gateway → P4	Webhook: `POST /payment-webhook` with HMAC signature	Medium–High	Integrity
	P4 → Risk Analysis Service	Anonymized transaction metadata for fraud scoring	Medium	Confidentiality

3. Main Activities and Steps

Step 3 –

The Third-Party Zone



3. Main Activities and Steps

Step 4 – Identify Preliminary Threats (Boundary-Level STRIDE)

⚠ *Note:* At this phase, STRIDE is applied at a **high level** to identify general risks **across trust boundaries**, not per component.

A. Apply STRIDE at system entry/exit points:

- Spoofing → Authentication needs
- Tampering → Integrity of data crossing boundaries
- Information Disclosure → Encryption needs
- Denial of Service → Resource protection
- Elevation of Privilege → Authorization control

B. Document potential risks and mitigation ideas.

C. Output: **Preliminary Threat List (Boundary STRIDE Table).**

3. Main Activities and Steps

1. Public Internet Boundary

STRIDE	Threat Description	Mitigation / Security Control
Spoofing	Fake customer or impersonation during login	Implement MFA, CAPTCHA, and strong session tokens
Tampering	Manipulating registration or product query parameters	Use HTTPS/TLS, input validation, and HMAC-signed requests
Repudiation	Customer denies submitting registration or checkout request	Maintain secure audit logs with timestamps
Information Disclosure	Exposure of credentials or personal info via insecure channels	TLS encryption, secure cookies, and CSP headers
Denial of Service	Excessive requests to login or product API	Rate limiting, WAF, auto-scaling defenses
Elevation of Privilege	Exploiting weak session management to gain admin access	Harden authentication services, session invalidation on logout

3. Main Activities and Steps

2. PCI External Boundary

STRIDE	Threat Description	Mitigation / Security Control
Spoofing	Forged payment initiation requests from fake checkout source	Mutual TLS or signed API keys between components
Tampering	Altering cart or tokenized payload during transit	Digital signatures, message authentication codes (MAC)
Repudiation	Payment gateway disputes due to unlogged transactions	Non-repudiation via signed transaction logs
Information Disclosure	Leaking tokenized data or cart metadata	Use tokenization, encrypt sensitive headers
Denial of Service	Flooding payment integration endpoints	Use load balancers, request throttling, IP blacklists
Elevation of Privilege	External attacker gaining access to internal gateway	Isolate via reverse proxy and network ACLs

3. Main Activities and Steps

3. PCI Internal (CDE) Boundary

STRIDE	Threat Description	Mitigation / Security Control
Spoofing	Unauthorized system simulating payment TX sender	Mutual authentication with certificates
Tampering	Alteration of encrypted payment data or logs	Integrity verification (hashes, digital signatures)
Repudiation	Missing log of transaction actions	Immutable audit trail, signed logging
Information Disclosure	Leakage of PAN or payment records	Full encryption at rest, key management controls
Denial of Service	Overload on encryption or TX DB	Resource monitoring, failover clustering
Elevation of Privilege	Gaining admin rights on CDE servers	Role-based access control (RBAC), least privilege policies

3. Main Activities and Steps

4. Internal Network Boundary

STRIDE	Threat Description	Mitigation / Security Control
Spoofing	Fake order management service sending bogus updates	Service-to-service authentication with JWT/OAuth2
Tampering	Modifying order or fulfillment data in transit	Encrypt communication (TLS), message integrity checks
Repudiation	Internal staff denies data updates	Secure logging and digital signatures
Information Disclosure	Exposure of order details	Encrypt internal traffic, restrict DB query scopes
Denial of Service	Overloaded order or reporting DB	Implement circuit breakers, caching layers
Elevation of Privilege	Gaining higher system privileges internally	Enforce least privilege, separate duties

3. Main Activities and Steps

5. Admin Network Boundary

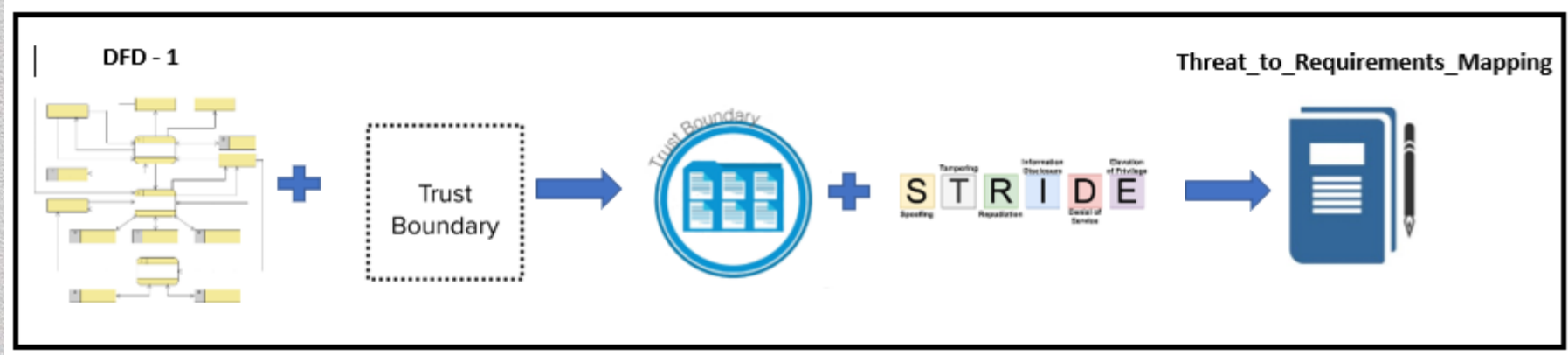
STRIDE	Threat Description	Mitigation / Security Control
Spoofing	Fake admin login or session hijack	MFA, secure tokens, IP whitelisting
Tampering	Altering configuration or audit exports	Digital signatures, config immutability
Repudiation	Admin denies user modification	Tamper-evident logs, accountability controls
Information Disclosure	Leakage of credentials or system reports	Encrypt traffic, limit session duration
Denial of Service	Targeting admin API to lock users out	Redundant admin endpoints, monitoring
Elevation of Privilege	Normal admin gaining super-admin rights	RBAC, privilege separation, approval workflows

3. Main Activities and Steps

6. Third-Party Network Boundary

STRIDE	Threat Description	Mitigation / Security Control
Spoofing	Fake payment gateway webhook	Verify HMAC signature and source IP
Tampering	Altering webhook payload	Use signed and timestamped requests
Repudiation	Gateway denies sending webhook	Require signed receipts, store headers
Information Disclosure	Leaking risk analysis data	Pseudonymize and encrypt data exchanges
Denial of Service	Continuous fake webhook posts	Validate rate and origin, limit retries
Elevation of Privilege	Third-party gains excessive system privileges	API scoping, limited access tokens

3. Main Activities and Steps



3. Main Activities and Steps

Step 5 – Map Threats to Security Requirements

- Link identified threats to existing requirements (RCM/CTM).
- Identify any missing security requirements and add them.
- Categorize controls as Preventive, Detective, or Corrective.
- Output: **Threat–Requirement Mapping Matrix.**

The output document can be seen in

Chapter4/Case Study/ Excel/ Threat_to_Requirements_Mapping_Classified.xlsx

3. Main Activities and Steps

🎯 Goal

To ensure that **every boundary threat** has at least one **security requirement** mitigating it, and to classify each control as:

- **Preventive (P)** – stops an attack before it happens
- **Detective (Dt)** – identifies or records it
- **Corrective (C)** – restores or limits damage after detection

3. Main Activities and Steps

Step 6 – Create Requirement Traceability Matrix (RTM)

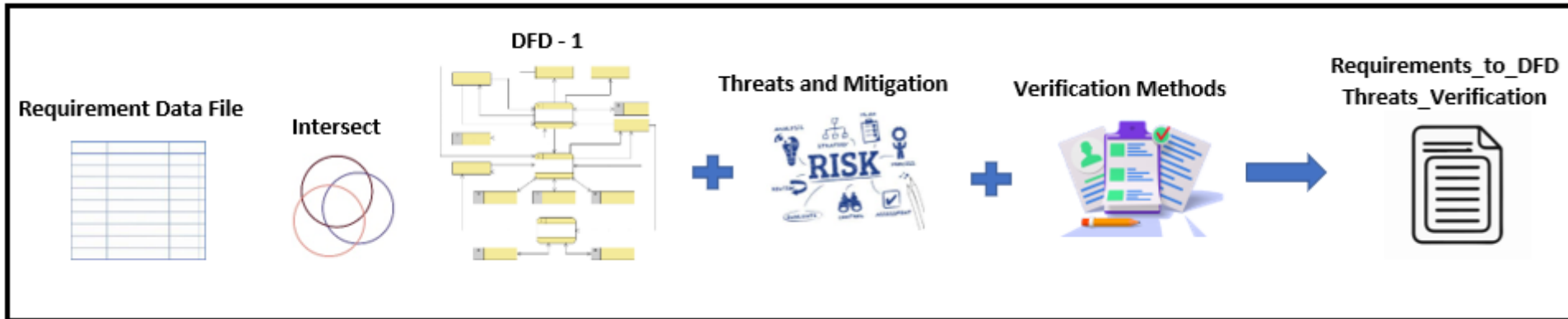
- Connect each requirement to:
 - DFD process or data flow,
 - Threat(s) it mitigates, and
 - Verification method (to be used later in testing).
- Output: **RTM linking Requirements → Threats → Verification.**

View the document:

Chapter4/Case

Study/Excel/Requirements_to_DFD_Threats_Verification.xlsx

3. Main Activities and Steps



3. Main Activities and Steps

🎯 Purpose

To prove **end-to-end coverage**:

- *What we designed (DFD)*
- *What could go wrong (Threat)*
- *How we protect (Requirement)*
- *How we verify (Test / Audit)*

6. Deliverables from Analysis Phase

At the end of this phase, you should have:

- **Requirements to DFD Threats Verification**
- **Threat to Requirements Mapping Classified**
- **DFD to Requirements Mapping**

Those 3 requirement files are found in your project file shown by your professor

7. Chapter Project – Analysis Phase

Starting Your Project

Complete the work on you project by creating the needed files for the scenario that you chose in the requirement phase

